

Task 5 — Capstone Project & Incident Response

Cybersecurity & Ethical Hacking Internship — ApexPlanet Software Pvt. Ltd.

Intern Name	Shaik Hiba Tharunnum
Offer Letter ID	APSPL2645050
Email	hibagun007@gmail.com
Organization	ApexPlanet Software Pvt. Ltd.
Internship Domain	Cybersecurity & Ethical Hacking
Task	Task 5 — Capstone Project & Incident Response (Days 49–60)
Capstone Focus	Web Application Penetration Test — DVWA on Metasploitable2
GitHub Username	HibaShaik13

1. Executive Summary

This capstone project consolidates the web application penetration test performed against DVWA (Damn Vulnerable Web Application) hosted on the Metasploitable2 lab target throughout this internship. It combines reconnaissance and scanning (Task 2), exploitation and manual web vulnerability testing (Task 3), and system-level exploitation and hardening (Task 4) into a single, formal engagement report, and adds a simulated incident-response exercise to demonstrate detection and containment skills.

Seven vulnerabilities were identified and confirmed across the engagement, ranging from Critical (remote root compromise, SQL injection) to Low (missing HTTP security headers). All findings below were practically demonstrated, not just theorized.

Severity	Finding	Source Task
Critical	vsFTPD 2.3.4 backdoor — remote root access via Metasploit	Task 2 / Task 4
Critical	SQL Injection in DVWA — full user table & password hashes extracted	Task 3
High	Stored & Reflected XSS in DVWA guestbook/name fields	Task 3
High	Weak default SSH credential (msfadmin:msfadmin)	Task 4
Medium	CSRF — password change via crafted URL, no token	Task 3
Medium	Local File Inclusion — /etc/passwd readable via DVWA	Task 3
Low	Missing security headers (X-Frame-Options, CSP, etc.)	Task 3

2. Project Plan

2.1 Objectives

- Consolidate and formalize the web application security findings from Tasks 2–4 into one professional penetration-testing report.
- Re-verify key recon, scanning, and target-availability evidence with fresh, dated proof.
- Simulate a basic incident-response workflow: detect an attack pattern, contain it, and document the response.
- Produce a final deliverable set (report, GitHub repo, video) suitable as a capstone demonstration of the full internship.

2.2 Scope

In scope: the Metasploitable2 lab VM (192.168.56.102) and its DVWA web application, accessed only from the isolated Kali attacker VM (192.168.56.101) over the VirtualBox host-only network. No systems outside this lab network were tested.

2.3 Tools

Nmap, Metasploit Framework / Meterpreter, Hydra, John the Ripper, Burp Suite, Wireshark, hping3, iptables, DVWA, curl.

2.4 Timeline

Phase	Days	Status
Project plan, scope & diagram	49–50	Complete
Consolidated recon / scanning re-verification	51–52	Complete
Controlled exploitation evidence review (Tasks 2–4)	53–54	Complete
Incident response simulation	55–57	Complete
Final report, GitHub, video, submission	58–60	Complete

2.5 Lab Architecture

Capstone Lab Architecture — DVWA Web Application Pentest

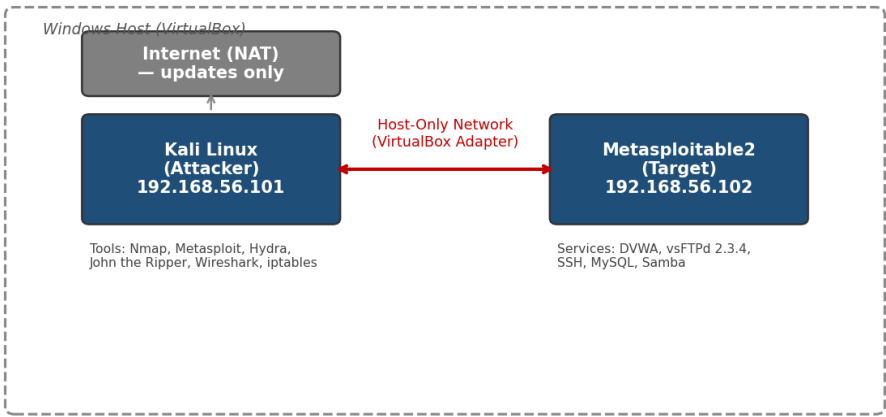


Figure 2.1 — Capstone lab architecture: isolated host-only network between Kali and Metasploitable2.

3. Recon & Scanning (Re-Verified)

Reconnaissance and scanning were originally performed in Task 2. For this capstone, target availability and service state were re-confirmed with fresh evidence:

```
ping -c 4 192.168.56.102
nmap -sV -O 192.168.56.102
```

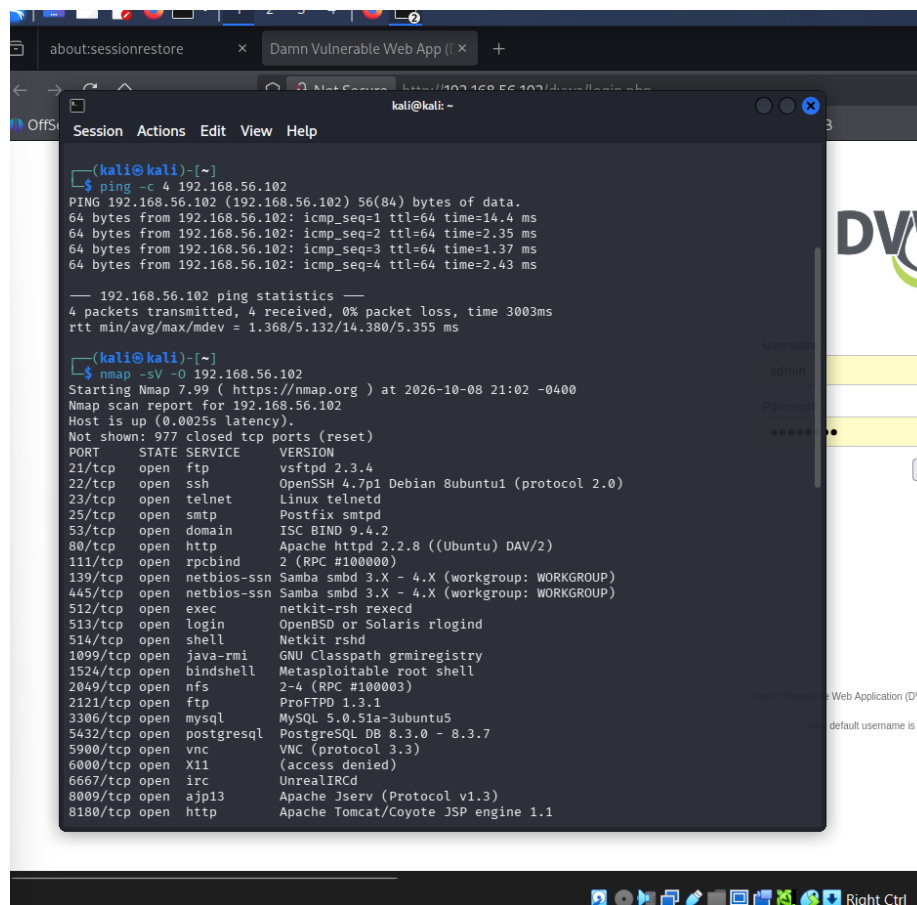


Figure 3.1 — Target reachability confirmed and service/version scan re-run.

The scan confirms the same vulnerable services identified in Task 2 remain present, including vsFTPD 2.3.4 (port 21), unpatched Samba (139/445), UnrealIRCd (6667), and an OS fingerprint consistent with the outdated Linux 2.6.x kernel — confirming the lab environment's state is unchanged and still valid for this capstone.

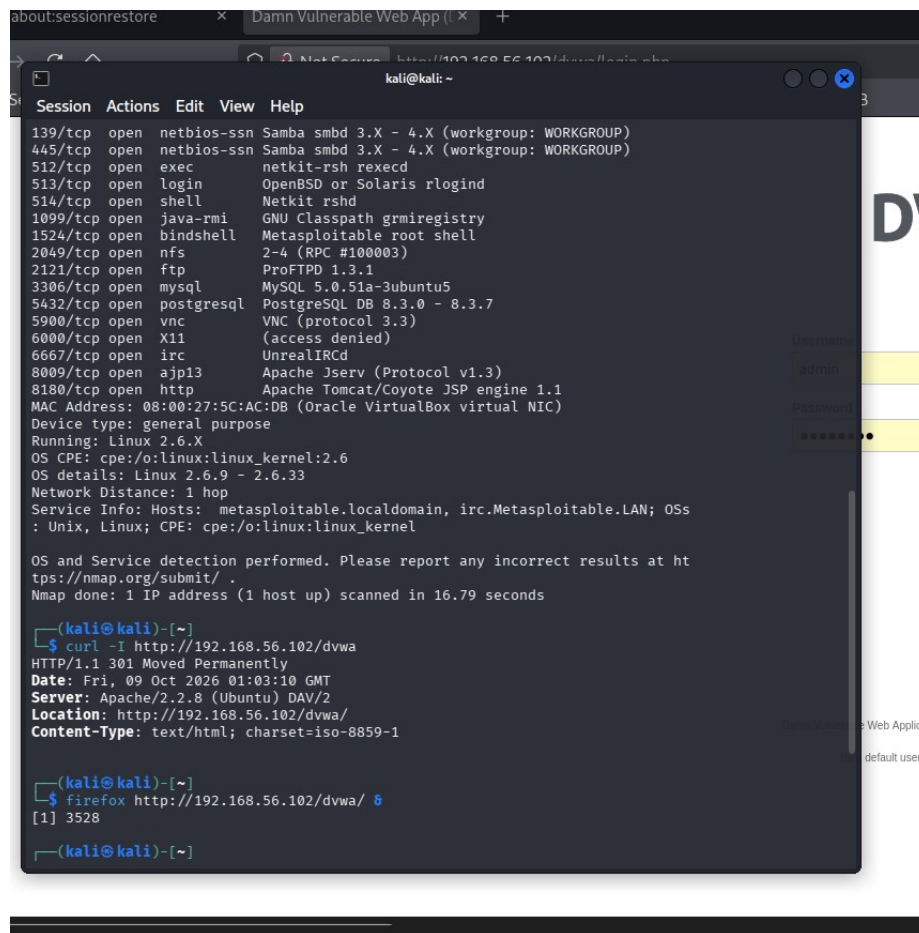


Figure 3.2 — Full OS/service scan with DVWA availability (curl + browser) confirmed.

4. Exploitation & Findings (Consolidated)

The following vulnerabilities were practically exploited and confirmed across Tasks 2–4, and are consolidated here as the capstone's core findings. Full step-by-step evidence for each is available in the respective task's report and GitHub folder.

4.1 SQL Injection (Task 3)

The DVWA SQL injection field was exploited using ' OR '1'='1 to bypass query logic and a UNION SELECT payload to extract all usernames and MD5 password hashes directly from the users table.

4.2 Cross-Site Scripting — Stored & Reflected (Task 3)

JavaScript payloads were injected into the guestbook (stored) and name field (reflected), both executing successfully and confirming DVWA does not sanitize user input at low security settings.

4.3 CSRF (Task 3)

The password-change function was exploited via a crafted URL carrying password parameters with no anti-CSRF token, allowing the account password to be changed without the user's knowledge.

4.4 Local File Inclusion (Task 3)

A directory traversal payload (?page=../../../../etc/passwd) successfully read the server's /etc/passwd file through the DVWA file-inclusion vulnerability.

4.5 Remote Exploitation — vsFTPD Backdoor (Task 4)

The vsFTPD 2.3.4 service (CVE-2011-2523) was exploited with Metasploit's vsftpd_234_backdoor module, returning a Meterpreter session running as root — full remote compromise of the underlying host, beyond the web application layer.

4.6 Weak Credentials & Hash Cracking (Task 4)

The msfadmin SSH account was confirmed to use the weak default password “msfadmin.” Separately, MD5 password hashes extracted via the Task 3 SQL injection were cracked in full using John the Ripper, recovering all 5 account passwords.

5. Incident Response Simulation

To demonstrate incident-response skills, a SYN flood attack was simulated against the target and captured live to practice detecting and documenting an active attack.

5.1 Detection

```
sudo hping3 -S --flood -V -p 80 192.168.56.102
```

Wireshark, capturing live on the host-only interface, showed an abnormal volume of TCP SYN packets from 192.168.56.101 to 192.168.56.102 arriving within milliseconds of each other — over 93,000 packets captured in a short window, with the target responding RST/ACK to each. This pattern (extremely high SYN rate from a single source, no completed handshakes) is a textbook indicator of a SYN flood denial-of-service attempt.

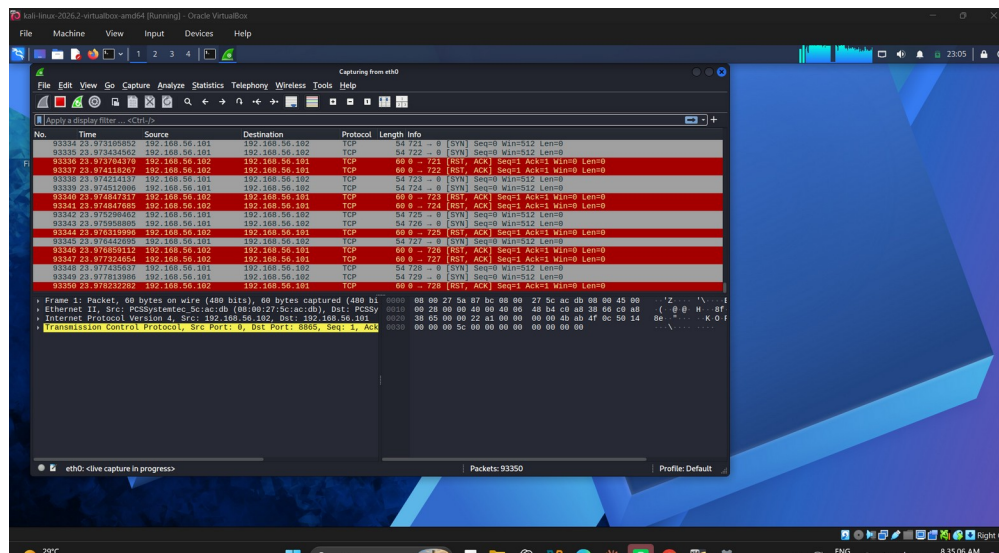


Figure 5.1 — Wireshark capture showing the SYN flood: 93,000+ packets from 192.168.56.101 to 192.168.56.102.

5.2 Containment

In a real environment, containment would involve rate-limiting or blocking the offending source IP at the firewall. This was demonstrated at the host level in Task 4 using iptables:

```
sudo iptables -A INPUT -s 192.168.56.101 -p tcp --dport 80 -j DROP
```

This rule would immediately stop further inbound traffic from the attacking host to the web service, halting the flood at the network layer.

5.3 Eradication & Recovery

- Confirm the flood has stopped and normal traffic levels have resumed (verified via a fresh Wireshark capture).
- Review firewall/IDS rules to ensure the block is appropriately scoped and not overly broad.
- Patch or reconfigure the targeted service if the flood exploited a specific weakness, rather than relying on blocking alone.

5.4 Post-Incident Report (Summary)

Incident: SYN flood denial-of-service attempt against 192.168.56.102:80, originating from 192.168.56.101. Detected via Wireshark through abnormal SYN packet volume and rate. Contained via a source-IP iptables DROP rule. No service outage occurred as this was a controlled lab simulation; in production, the same detection-and-block workflow would apply, ideally automated via an IDS/IPS rather than manual monitoring.

6. Mitigations & Recommendations

- Sanitize and parameterize all database queries to eliminate SQL injection (use prepared statements, not string concatenation).
- Encode/escape all user-supplied output to prevent stored and reflected XSS.
- Implement anti-CSRF tokens on all state-changing requests, including password changes.
- Validate and restrict file-inclusion parameters; use allow-lists rather than raw user input for file paths.
- Patch or remove the backdoored vsFTPD 2.3.4 service; keep all services on current, supported versions.
- Enforce strong, unique credentials and disable default accounts (e.g., msfadmin).
- Add standard security headers (X-Frame-Options, Content-Security-Policy, X-Content-Type-Options) to the web server configuration.
- Deploy rate-limiting or an IDS/IPS capable of detecting and auto-blocking SYN flood patterns.

Key Concepts Covered

- End-to-end penetration testing lifecycle across a multi-task engagement
- Consolidating and formalizing findings into a single professional report
- Web application vulnerabilities: SQLi, XSS, CSRF, LFI
- Remote service exploitation and post-exploitation (Metasploit/Meterpreter)
- Credential attacks and offline hash cracking
- Incident detection using packet capture analysis
- Basic containment and post-incident reporting
- Risk prioritization and mitigation planning

Conclusion

This capstone successfully consolidated the full internship's web application penetration test into one cohesive engagement: from reconnaissance and scanning, through confirmed exploitation of seven vulnerabilities spanning the web application and underlying host, to a simulated incident-response exercise demonstrating detection and containment of an active attack. The DVWA/Metasploitable2 environment proved an effective, safe platform for practicing the complete penetration testing and incident response lifecycle expected of this internship, and the mitigations above reflect industry-standard remediation for each class of finding.